

Actividad final integradora: Propuesta de hacking ético para Fiordo Escolar

PF1495 · Hacking Ético en Aplicativos Web
Módulo 2 · MA03807 · Introducción al hacking ético

MOMENTO

Al cierre del módulo, después del último ABPRO

MODALIDAD

Individual, con entrega en el LMS

CALIFICACIÓN

Pauta de 40 puntos por componentes de la competencia, exigencia 60 %

COMPETENCIA DEL MÓDULO

Explicar los conceptos fundamentales de ciberseguridad y los principios éticos del hacking, identificando el rol del hacker ético en la protección de los sistemas informáticos acorde a las prácticas y normativas vigente

Contexto

Librería Fiordo (empresa ficticia), la tienda que te acompañó todo el módulo, lanzará **Fiordo Escolar**: un portal donde los colegios publican sus listas de textos y los apoderados compran con su cuenta, registrando el nombre, el curso y el colegio de cada estudiante. El portal tiene inicio de sesión, carro de compras, pago con un proveedor externo y un panel donde cada colegio administra sus listas.

La gerencia teme lo que ya vio en la tienda: correos falsos, fallas que exponen datos de clientes y personas que «prueban» el sitio sin permiso. Esta vez guarda datos de niños y niñas, y no quiere lanzar el portal sin una prueba de seguridad.

El desafío

La gerencia te pide una **propuesta de hacking ético** para Fiordo Escolar que pueda leer alguien sin formación técnica: qué podría salir mal, en qué marco ético y legal se hará la prueba, quién la hará y cómo. Puedes reutilizar lo que tu equipo construyó en «Mapa de amenazas de Librería Fiordo», «Reglas de la prueba de Librería Fiordo», «Equipo y protocolo de conducta para Librería Fiordo» y «Plan de prueba de la tienda de Librería Fiordo», adaptado al portal nuevo; indica qué reutilizaste y qué cambiaste.

Condiciones:

- **Es individual.** Puedes consultar las lecturas del módulo y preguntar en el foro, sin compartir tu propuesta.
- **Solo en tu laboratorio.** La práctica de la Parte 4 se hace en OWASP Juice Shop o DVWA instalados en tu propio equipo, nunca en un sitio real ni de terceros.

- **Sin código ofensivo.** No se pide ni se acepta desarrollar ataques: la propuesta describe qué se probaría y cómo se documentaría.
- **Cita tus fuentes** cuando uses leyes, normas, códigos de ética o casos reales.

Qué tienes que entregar

Un informe PDF de 4 a 6 páginas con cinco partes:

1. **Qué podría salir mal.** Define en un glosario breve los términos clave de ciberseguridad y hacking ético que usarás. Identifica cinco amenazas o vulnerabilidades probables del portal (al menos dos vulnerabilidades web comunes y una amenaza que no sea técnica, como el phishing), con su origen interno o externo y el tipo de atacante que podría aprovecharlas. Describe cómo avanzaría uno de esos ataques según la cyber kill chain y ejemplifica, en una tabla, el impacto de cada caso para la librería y para las familias.
2. **El marco de la prueba.** Explica los principios del hacking ético que guiarán la prueba y qué metodologías y certificaciones darían confianza a la librería. Describe qué implican para el portal la Ley 21.459 de delitos informáticos, la ley de protección de datos personales (Ley 19.628 y su reforma por la Ley 21.719, con atención a los datos de menores), la propiedad intelectual y los tratados de cooperación internacional, sin citar artículos. Compara en pocas líneas los códigos de ética de EC-Council y del Instituto SANS, explica qué aportan ISO/IEC 27001, NIST SP 800-53 y OWASP TG, y toma posición frente a un debate ético o legal del hacking ético.
3. **Quién hace la prueba y cómo se comporta.** Propón los perfiles del equipo (pentester, analista de seguridad, auditor/a de seguridad) con sus responsabilidades. Redacta el borrador de autorización: qué se prueba y qué no (el proveedor de pagos y los sistemas de los colegios quedan fuera), quién la firma y cuándo se detiene la prueba. Agrega cinco reglas de conducta sobre consentimiento, confidencialidad y privacidad, transparencia y comunicación, conflicto de interés y responsabilidad profesional.
4. **Cómo se hará la prueba.** Presenta un plan por fases (reconocimiento, enumeración, explotación, post-explotación e informe) con su objetivo, herramientas o técnicas y evidencia esperada, basado en la guía de pruebas de OWASP y en PTES. Reparte un plazo de 10 días hábiles entre las fases, priorizando lo crítico. Ensayá el reconocimiento en tu laboratorio y adjunta tres capturas con lo que encuentraste.
5. **Lo que recibirá la librería.** Propón el índice del informe final de la prueba y redacta, como ejemplo, la ficha de un hallazgo ficticio: descripción, severidad, impacto, evidencia mínima con los datos personales ocultos y recomendación.

Pauta de evaluación

Cada fila se asigna completa si se cumple, a la mitad si se cumple en parte y en cero si no está.

Componente de la competencia	Qué se revisa	Puntos
Explicar los conceptos fundamentales de ciberseguridad	Parte 1	10

Componente de la competencia	Qué se revisa	Puntos
	Glosario correcto y usado con coherencia en todo el informe	2
	Cinco amenazas o vulnerabilidades del portal, con origen y tipo de atacante	3
	Un ataque descrito paso a paso según la cyber kill chain	2
	Tabla de impacto para la librería y para las familias	3
Los principios éticos del hacking	<i>Partes 2 y 3</i>	10
	Principios, metodologías y certificaciones del hacking ético, aplicados al portal	3
	Comparación de los códigos de ética y posición fundamentada en el debate	3
	Cinco reglas de conducta concretas, incluido el conflicto de interés	4
Identificando el rol del hacker ético en la protección de los sistemas informáticos	<i>Partes 3, 4 y 5</i>	12
	Perfiles del equipo con responsabilidades claras	2
	Plan por fases con objetivo, herramientas y evidencia, basado en OWASP y PTES	4
	Plazo repartido con prioridades y ensayo de reconocimiento con capturas del laboratorio	3
	Índice del informe y ficha de un hallazgo con evidencia mínima	3
Acorde a las prácticas y normativas vigente	<i>Partes 2, 3 y 4</i>	8
	Leyes chilenas y tratados explicados sin inventar contenido, con atención a los datos de menores	3
	Normas ISO/IEC 27001, NIST SP 800-53 y OWASP TG bien diferenciadas	2
	Borrador de autorización con alcance, exclusiones y condiciones de detención; práctica solo en laboratorio propio	3
Total		40

Nota (exigencia 60 %): si el puntaje p es mayor o igual que 24, $\text{nota} = 4,0 + 3 \times (p - 24) / 16$; si es menor, $\text{nota} = 1,0 + 3 \times p / 24$. Se redondea a un decimal. Por ejemplo: 20 puntos, 3,5; 24 puntos, 4,0; 32 puntos, 5,5; 40 puntos, 7,0.